Ders 9 Lab Çalışma Özeti

Ders 9 Lab Çalışma Özeti

Genel Konular

- SQL injection seviyelerinin derinleştirilmesi
  - Düşük seviyedeki doğrudan sorgu manipülasyonundan sonra daha fazla kontrol, filtreleme ve doğrulama içeren senaryolar incelenir.
  - Saldırı girdisinin uygulama katmanı ve veritabanı katmanı arasında nasıl yorumlandığı gözlemlenir.
- Veritabanı keşfi
  - Metadata tabloları, tablo/kolon adları, kullanıcı kayıtları ve hassas alanların bulunması SQL injection uygulamasının temel adımlarıdır.
- Savunma etkisi
  - Filtreleme, tırnak kaçışlama ve sorgu yapısındaki küçük değişikliklerin saldırı yöntemini nasıl etkilediği değerlendirilir.

Hocanın Özellikle Vurguladığı Kısımlar

- Saldırı tek komuttan ibaret değildir
  - SQL injection keşif, doğrulama, veri çıkarma ve yetki değerlendirme aşamalarından oluşur.
- Filtreleme yeterli olmayabilir
  - Esas savunma parametreli sorgu ve veritabanı yetki sınırlandırmasıdır.

Kısa Tekrar Notları

- SQL injection aşamalı ilerler.
- Metadata tabloları veritabanı şemasını açığa çıkarabilir.
- Hata mesajları keşfi hızlandırır.
- Parametreli sorgu temel savunmadır.

Detaylı Açıklamalar

- Laboratuvar içeriğinde saldırgan bakış açısıyla önce zafiyetin varlığı doğrulanır, ardından sorgu yapısı anlaşılır. Kolon sayısı, veri tipleri ve dönen sonuç alanları belirlendikten sonra `UNION` gibi yöntemlerle sistem tablolarından bilgi elde edilir.
- Savunma tarafında yalnızca belirli karakterleri filtrelemek saldırıyı tamamen durdurmayabilir. Farklı kodlama biçimleri, yorum işaretleri, alternatif SQL söz dizimleri veya uygulama mantığı filtreleri aşabilir. Bu nedenle SQL komutu ile kullanıcı verisinin yapısal olarak ayrılması gerekir.
- **Not:** İsterseniz bu dersin altyazı (.srt) dosyasını Gemini Notebook gibi bir yapay zeka aracına yükleyerek ders hakkında daha detaylı soru-cevaplar yapabilir ve dersi verimli çalışabilirsiniz.